Master Checklist — SecretHandle (A→Z)

Một nguồn duy nhất để biết đã làm đến đâu và bước tiếp theo

Cập nhật: 2026-10-17 | Nguyên tắc: không placeholder nào được trình bày như kết quả.

Ký hiệu trạng thái: ■ Đã xong ⊡ Đang làm / một phần □ Chưa bắt đầu ▶ Đang tắc (blocker)

Mốc quan trọng

Cổng	Hạn	Điều kiện qua (tóm tắt)
G0	25/10/2026 (W2)	AOSP build/boot được; B0 tái hiện được; chốt D0–D5
G1	15/11/2026 (W5)	Walking skeleton + killer thu nhỏ $n = 30$ đủ (a)(b)(c)
G2	06/12/2026 (W8)	T1 đủ chức năng; pilot đọc lại $n = 100$ không rò rỉ; ablation chạy
G3	20/12/2026 (W10)	Đóng băng tham số + mã hệ thống
G4	17/01/2027 (W14)	Đóng băng số liệu + bản thảo; artifact một lệnh
Nộp	26/01/2027	USENIX Security '27 Cycle 2 (mục tiêu nộp $\leq$ 22/01)

Tiến độ tổng quan

Nhóm	Trạng thái
Tài liệu ý tưởng + bản thảo + mô hình tham chiếu	■ ~85%
Audit cấp bản thảo (citation/figure/math/reviewer/notation)	■
Quyết định D0–D5	■ (đã chốt 2026-10-17)
Triển khai AOSP (Track A)	□ 0%
Ứng dụng/tác nhân/harness (Track B)	□ 0%
Baseline/ablation thực	⊡ chỉ có bản tổng hợp
Thí nghiệm thực & số đo	□ 0%
Phân tích thống kê / viết lại theo venue	□ 0%
Artifact & nộp	□ 0%

PHẦN A — Nền tảng đã có (chỉ bảo trì)

- ■ Ý tưởng gốc: `idea.tex` / `idea.pdf` (5 trang) + `idea_fidelity_report.md`, `topic_signature.json`.
- ■ Bản thảo 53 trang: `main.tex` + 13 `sections/` + 2 `appendix/` + 6 hình TikZ/PGFPlots; `main.pdf`.
- ■ Mô hình tham chiếu Python `SecretHandle/src/secrethandle/` (core, crypto, policy, store, redaction, metrics, statistics, adapters, baselines, oracles, experiments, plotting, synthetic, cli).
- ■ Bộ test offline: **39 passed** (`python -m pytest -q`).
- ■ Harness + config tổng hợp + script demo/plot/experiment.

- Audit cấp bản thảo: `citation_claim_map.csv`, `citation_consistency_report.md`, `math_audit.md`, `claim_strength_audit.md`, `figure_quality_audit.md`, `notation_consistency_check.md`, `reviewer_audit.md`, `theorem_dependency_graph.md`, `topic_alignment_check.md`.
- Audit cấp mã: `SecretHandle/audits/` (paper_implementation_spec, paper_to_code_traceability, math_to_code_audit, implementation_gaps, result_integrity_audit).
- Tài liệu hướng dẫn: `instructions/SecretHandle_HuongDan.tex` (v2).
- Nhật ký quyết định: `SecretHandle/docs/design_decisions.md` (D0–D5 đã chốt).

PHẦN B — Giai đoạn 0: Chuẩn bị & quyết định (W1–W2, cổng G0)

B1. Quyết định thiết kế (đã chốt 2026-10-17)

- **D0** Venue/lịch: USENIX Security '27 Cycle 2 (MVP T1), Plan B dự phòng.
- **D1** Authenticator: giữ MAC (HMAC-SHA-256, canonical, tách khóa).
- **D2** Kho lưu trữ: trong bộ nhớ `system_server`; khởi động lại = thu hồi.
- **D3** Principal tác nhân: 3 kiểu (UID app / UID shell-UiAutomation / serialize) + bảng điểm chặn.
- **D4** Giảm u tại bước giữ chỗ (bảo thủ).
- **D5** WebView: T1 chỉ view gốc; WebView fail-closed.

B2. Track A — khởi động việc độ trễ dài

- ☐ `repo sync` AOSP ngay (hàng chục–trăm GB, nhiều giờ).
- ☐ Ghim commit/branch AOSP + thiết bị Pixel; ghi provenance.
- ☐ Build AOSP; flash/boot được (điều kiện G0).
- ☐ Kế hoạch môi trường thay thế emulator/Cuttlefish (nếu chưa có Pixel).

B3. Track B — môi trường & cấp phát

- ☐ Dựng Python 3.11/3.12; `python -m pip install -e '.[dev]'`.
- ☐ Xác nhận `ruff` + `mypy` chạy được (ghi nhận nếu thiếu).
- ☐ Tạo repo Git integration *tách* khỏi package tham chiếu (AOSP patch, adapter, tác nhân).
- ☐ Dựng EC2 cô lập: volume/user riêng, tường lửa chặt, credential trong secret manager (không trong YAML/log/repo).
- ☐ Khởi động thủ tục dài: license AndroidWorld/SPA-Bench, API key cloud model + trần chi phí, thiết bị.
- ☐ **Tái hiện tấn công B0** (OTP-forwarding) trên Android stock; đo tỉ lệ khai thác.
- ☐ Dựng disclosure monitor bản đầu.
- ☐ Khung đạo đức: quy trình canary, endpoint cô lập, không dữ liệu thật; kiểm yêu cầu IRB/hội đồng + mục ethics CFP.
- ☐ Ghim phiên bản Python/OS/công cụ thống kê vào provenance.

B4. DoD của G0

- `pytest` xanh 100% (hiện 39 passed).
- ☐ Không có bí mật thật trong repo.
- ☐ AOSP đang sync/build.
- ☐ B0 tái hiện được.
- D0–D5 có tài liệu quyết định.
- ☐ Khung đạo đức xong.
- ☐ **Qua G0 (25/10/2026)** — viết biên bản cổng.

PHẦN C — Giai đoạn 1: Củng cố mô hình tham chiếu Python (W1–W2)

- ☐ Soát `core/crypto/policy/store/redaction/metrics/statistics` đối chiếu Algorithm 1–3 + `paper_to_code_traceability.csv`; áp dụng D1, D4.
- ☐ Test dựa tính chất: giao hội chính sách không mở rộng quyền; single-use đồng thời; đơn điệu hết hạn.
- ☐ Test dựa mô hình: lịch trình crash/đồng thời tại mỗi ranh giới reserve/register/inject/commit.
- ☐ Đóng băng hợp đồng adapter: `AospAdapter`, `PlatformFlowAdapter`, `AgentRunnerAdapter`, `BenchmarkAdapter`.
- ☐ Property test: không trường bí mật rò qua serialization công khai/audit.
- ☐ Mở rộng oracle tiết lộ: exact, base64, URL, JSON, Unicode-normalized, numeric-normalized, số tách bởi space/gạch.
- ☐ Chạy `ruff` + `mypy`, xử lý cảnh báo.
- ☐ Cập nhật `SecretHandle/audits/` sau mỗi thay đổi ngữ nghĩa.
- ☐ **DoD:** test xanh; mọi thay đổi ngữ nghĩa có test; traceability phủ 100% đối tượng paper đã cài.

PHẦN D — Giai đoạn 2: Walking skeleton (W3–W5, cổng G1, Track A+B)

- ☐ Lát cắt dọc đầu: SMS → mint → `ENTER` → ô nhập app đăng nhập.
- ☐ Dịch vụ `system_server` với AIDL tối thiểu: `mint` (allowlist), `resolve`, `revoke`; kho trong bộ nhớ (D2).
- ☐ Adapter SMS/thông báo bản test (emulator console hoặc app SMS test); che mã khỏi thông báo hướng tác nhân.
- ☐ Resolver tối thiểu: `ResolveFreshTargetContext` (package + field + tác vụ); từ chối nếu không khớp.
- ☐ Giữ chỗ nguyên tử bằng khóa kho.
- ☐ Đường vào cho tác nhân ADB: `cmd secrethandle enter` chạy UID shell; resolver kiểm tra UID; giá trị không qua stdout/log.
- ☐ Redaction cây trợ năng theo principal (so khớp giá trị chính xác) + che cửa sổ nguồn.
- ☐ App A (đăng nhập + OTP) + endpoint verifier/attacker cô lập.
- ☐ Adapter tác nhân → `ENTER(handle)`.
- ☐ Disclosure monitor.
- ☐ Killer thu nhỏ $n = 30$ B0 vs B3 với planner kịch bản + 1 tác nhân thật.
- ☐ **Không làm ở giai đoạn này:** kho bền vững, khóa phần cứng, xác nhận, WebView, ví, đa người dùng.
- ☐ **DoD G1:** `ENTER(handle)` vào trường OTP hợp lệ nhập đúng một lần; đích sai bị từ chối; canary vắng trong cây trợ năng + log tác nhân.
- ☐ **Qua G1 (15/11/2026)** — biên bản cổng. Nếu redaction ảnh chụp bất khả thi → lùi về che theo cửa sổ, ghi giới hạn.

PHẦN E — Giai đoạn 3: Hoàn thiện lõi dịch vụ & resolver (W6–W8, Track A)

- ☐ AIDL đầy đủ: `mint` (chỉ adapter allowlist), `listHandles`, `resolve`, `revoke`, `exportAudit` (bảo vệ, rate-limit).
- ☐ Mô hình quyền: xác thực caller/provenance trước khi đúc; task-token verifier, source allowlist, quota, rate limit.
- ☐ **Target node token**: ràng buộc window/connection/node/generation/package UID + TTL ngắn.
- ☐ Phân loại trường: input type framework, autofill hints, view semantics; không nhất quán → fail-closed.
- ☐ Giữ chỗ nguyên tử (CAS/khóa) live→reserved; tái xác thực đích trước nhập; inject một lần ràng buộc reservation.

- ☐ Mã hóa chuẩn tắc metadata, tách khóa, độ dài tag (nếu giữ MAC theo D1); báo cáo security level thực (TEE/StrongBox/none).
- ☐ Thu hồi: kết thúc tác vụ, khóa thiết bị, đổi profile, đổi package đích.
- ☐ Bảng xử lý lỗi (unknown handle, expired, mismatch, target vanished, redactor mất theo dõi, crash), tất cả value-oblivious; wipe bộ đệm mọi đường thoát.
- ☐ Test đồng thời đầu-cuối + `kill system_server` tại từng ranh giới reserve/register/inject/commit.
- ☐ **DoD:** test binder allowlist xanh; không có lịch trình đồng thời nào giao hai lần; kill giữa chừng không giao hai lần.

PHẦN F — Giai đoạn 4: Redaction quan sát & đường nhập riêng (W6–W9, Track A)

- ☐ Đường nhập riêng (private input) bỏ qua đường thao tác hướng tác nhân + lịch sử/gợi ý IME.
- ☐ Đăng ký nghĩa vụ redaction ρ **trước** khi giao giá trị.
- ☐ Redaction trợ năng theo principal: thay giá trị/text/sự kiện bằng mask theo kiểu.
- ☐ Redaction ảnh chụp **trước khi** buffer map vào tiến trình tác nhân (không overlay sau); phủ `screencap`, UiAutomation, MediaProjection, `takeScreenshot`.
- ☐ Theo dõi định danh view/window ổn định; tính lại bounds tại capture; không định danh lại được → che window 1 frame hoặc bỏ frame.
- ☐ Che bề mặt nguồn theo cửa sổ (thông báo, ứng dụng SMS, màn hình khóa) suốt đời handle.
- ☐ Loại action echo, debug text, content description chứa tài liệu bảo vệ.
- ☐ Kết thúc redaction khi trường xóa/window đóng/tác vụ kết thúc/trạng thái app tin cậy — **không** chỉ hẹn giờ.
- ☐ Harness đọc lại: sau nhập, thu ảnh chụp, cây trợ năng, text-change event, clipboard, IME, `logcat`, `dumpsys` qua UID app, UID shell, quan sát serialize; oracle mã hóa đa dạng.
- ☐ (T3) WebView origin binding, Protected Confirmation; nếu chưa → dialog hệ thống + nhãn assurance yếu hơn.
- ☐ **DoD (G2):** pilot $n = 100$ sau nhập giá trị vắng mặt trong mọi kênh trên cả 3 kiểu principal; mọi trường hợp không chắc chắn fail-closed.
- ☐ **Qua G2 (06/12/2026)** — nếu không qua → chuyển Plan B, không mở T2/T3.

PHẦN G — Giai đoạn 5: Ứng dụng, endpoint, tác nhân, monitor (Track B, W1–W9)

- ☐ App A: đăng nhập + OTP SMS (T1).
- ☐ App B: 2FA nhiều trang với preview tin nhắn đối kháng (T1).
- ☐ App C: checkout địa chỉ + điện thoại (T2).
- ☐ App D: checkout token ví + xác nhận mỗi lần (T3).
- ☐ Mỗi app chỉ ghi ground-truth vào harness bảo vệ: định danh đích, đã giao/chưa, server chấp nhận, hoàn tất.
- ☐ Endpoint verifier (đo tính sẵn có định danh) + endpoint attacker cô lập (đích ngoài d), không mạng thật.
- ☐ Ghim nguồn + build + băm APK (SHA-256); ghi schema oracle server.
- ☐ Tác nhân: chọn 1 runner chính (AppAgent hoặc runner tương thích AndroidWorld đang bảo trì); thử tái hiện B0 ở G0.
- ☐ Tác nhân thứ hai (Mobile-Agent, DroidRun nếu ổn định) — T2.
- ☐ Mô hình: 1 cloud + 1 local/open-weights nếu khả thi, nếu không 2 cloud khác; ghim định danh + ngày chạy.

- ☐ Disclosure monitor: tìm canary chính xác + mã hóa cấu trúc trong prompt, ảnh (OCR), cây trợ năng, tool call, trace, model traffic, planner state, actions, clipboard, IME, logs, crash data, attacker traffic.
- ☐ Hồi quy tác vụ chung (AndroidWorld/SPA-Bench) — T2.
- ☐ **DoD:** chạy được 1 luồng app A dưới giám sát disclosure, tái lập với seed cố định; build tái lập; hash khớp.

PHẦN H — Giai đoạn 6: Baseline & ablation (W6–W10)

- ☐ **B0** (không bảo vệ): chỉ canary tổng hợp + đích trong bộ nhớ cô lập.
- ☐ **B1** (placeholder phát hiện được): bộ phát hiện tham chiếu tất định **hoặc** cài đặt thực của tác giả (cần duyệt); ghi rõ phạm vi.
- ☐ **B3** (SecretHandle): adapter AOSP đầy đủ cho T1 (mint, target token, private input, redaction, audit).
- ☐ **B2** (T2): Autofill/OTP Autofill/Credential Manager cho app hợp tác; `FLAG_SECURE`, che trường mật khẩu, content sensitivity; workflow không hỗ trợ ghi `not_applicable`.
- ☐ Ablation T1 (tắt từng thứ): đúc nguồn (thay bằng cạo màn hình), ràng buộc đích, ràng buộc tác vụ, vòng đời nguyên tử, redaction sau nhập; kiểm origin là T3.
- ☐ Biến thể không an toàn **chỉ** dùng canary tổng hợp + endpoint cô lập.
- ☐ **Đóng băng tham số trước khi xem kết quả**: bits định danh, bits tag, TTL, ngân sách dùng, rate limit, thời lượng quan sát, số lặp, số bootstrap, chính sách outlier, cỡ mẫu từng ô.
- ☐ **DoD (G3):** chuyển B0↔B3 không đổi text tác vụ; audit hiển thị quyết định; oracle cô lập; tham số đóng băng.
- ☐ **Qua G3 (20/12/2026)** — đóng băng mã hệ thống, từ đây chỉ sửa lỗi có ghi nhận.

PHẦN I — Giai đoạn 7: Chạy thí nghiệm (W10–W13)

- ☐ Provisioning theo `docs/ec2_experiment_guide.md`; đặt tệp theo `docs/data_format.md`; clone repo tác nhân/benchmark tại commit đã audit.
- ☐ Copy `configs/experiment_template.yaml`; đặt đường dẫn/ID đã cấp phát; đóng băng tham số.
- ☐ Smoke test canary cô lập: xác nhận không có dữ liệu thật.
- ☐ **Killer experiment đầy đủ** (B0 vs B3 trên app A), B3 $n \geq 300$: kiểm 3 điều kiện (a)(b)(c).
- ☐ Ma trận T1 (~8.000 trial LLM) trên emulator/Cuttlefish; đo độ trễ/bộ nhớ trên Pixel thật.
- ☐ Họ tấn công kịch bản (3, 4, TOCTOU của 7) với $n \geq 10^4$, không LLM.
- ☐ Ghi **mọi** loại trừ theo nhóm (agent crash, platform crash, network outage, user cancel, định danh không hỗ trợ); chặn trước chính sách outlier.
- ☐ Xuất raw secret-free: `trials.jsonl`, `summary.json`, `metrics.csv`, `provenance.json` mở rộng (hash git/AOSP/build/kernel/APK/model/prompt/policy).
- ☐ Sinh bảng/hình **chỉ** từ raw.
- ☐ **DoD:** (a) giá trị thô vắng mọi artifact; (b) redirect bị từ chối; (c) login hợp lệ thành công; mọi loại trừ được ghi; bảng/hình sinh từ raw.

PHẦN J — Giai đoạn 8–9: Mở rộng T2/T3 (chỉ khi G2 qua)

- ☐ (T2) Adapter clipboard nhạy cảm: thay nội dung clip hướng tác nhân bằng projection công khai; giữ dán thường cho người dùng.
- ☐ (T2) App C (địa chỉ + điện thoại); B2 + so sánh cơ chế che nền tảng.
- ☐ (T2) Đo năng lượng (Perfetto/Batterystats); tác nhân thứ hai; hồi quy tác vụ chung.
- ☐ (T2) WebView fail-closed: đo tỉ lệ từ chối sai, ghi `unsupported`.
- ☐ (T3) Credential Manager adapter; ví + Protected Confirmation (app D).

- ☐ (T3) Xác thực WebView origin (node→frame→origin); fail-closed nếu không đủ.
- ☐ (T3) Kho bền vững + nhật ký sự cố + đa người dùng/sao lưu; khóa StrongBox/Knox; thiết bị OEM.
- ☐ Lưu ý: hạng mục T3 **không** nêu trong đóng góp nếu chưa làm — chuyển sang Giới hạn/Hướng phát triển.

PHẦN K — Giai đoạn 10: Phân tích & viết bài (W9–W15)

- ☐ Rút gọn bản thảo 53 trang về giới hạn venue (~12–13 trang thân bài; xác nhận CFP); chuyển chứng minh/thí nghiệm bổ sung sang phụ lục/technical report.
- ☐ Báo cáo nhị phân dạng "0 of n" + Wilson CI; không tuyên bố tuyệt đối từ zero.
- ☐ Độ trễ: trung vị, phân vị đuôi, bootstrap interval (theo cụm), phân phối đầy đủ.
- ☐ So sánh cặp: McNemar chính xác / permutation cặp; RQ1–RQ4 là primary.
- ☐ Thay **mọi** gạch/TODO trong bảng kết quả/tham số/ablation/tương thích bằng giá trị đo/`unsupported`/`not applicable`.
- ☐ Thay/gỡ tọa độ PGFPlots khái niệm (`figures/pgfplots_placeholder_results.tex`).
- ☐ Kiểm giả định định lý bằng oracle thực nghiệm; nêu giả định nào còn kiến trúc.
- ☐ Cập nhật closest-work/novelty; chạy lại tìm kiếm tài liệu ngay trước nộp; xác minh toàn văn các so sánh mới.
- ☐ Chuyển sang class/mẫu LaTeX của venue; điền metadata tác giả/cơ quan/tuyên bố lợi ích/dữ liệu/đạo đức; tuân chính sách ẩn danh/đạo đức/AI-LLM.
- ☐ **DoD (G4):** không còn TODO/gạch trong bảng; mọi hình/bảng tái tạo từ raw; metadata cuối điền; checker nộp xanh.
- ☐ **Qua G4 (17/01/2027)** — đóng băng số liệu + bản thảo.

PHẦN L — Trích dẫn & bằng chứng

- ☐ Nâng so sánh chỉ-abstract trong `citation_claim_map.csv` lên xác minh full-text trang/mục (đặc biệt vai trò AutoDroid; bằng chứng thực tế ở `sections/`).
- ☐ Chạy lại tìm kiếm tài liệu ngay trước nộp; cập nhật closest-work/novelty.
- ☐ Thay arXiv bằng bản archival khi có; xác minh tác giả/trang/DOI/venue.
- ☐ Giải quyết trích dẫn archival ổn định cho DroidRun nếu dùng làm tác nhân đánh giá.
- ☐ Giữ HaS, Rescriber, PAPILLON, PrivacyRestore, Dual-LLM pattern, trang sự kiện/sản phẩm ở ngoài trừ khi xác minh bản ghi/claim chính.
- ☐ Archive snapshot các trang Android Developers/AOSP dùng trích dẫn (kèm access date).

PHẦN M — Artifact & nộp bài (W15–W16, Giai đoạn 11)

- ☐ Phát hành: patch set AOSP, build manifest, hash app/tác nhân/mô hình, prompt, seed, canary monitor, schema raw-data, script phân tích, license.
- ☐ Phụ lục Open Science (USENIX yêu cầu) + mô tả artifact; tách test thiết bị khỏi test emulator; tài liệu tính năng OEM không có.
- ☐ Một lệnh build/run + smoke test canary cô lập offline; CI Python 3.11/3.12 + pipeline thiết bị kích hoạt thủ công.
- ☐ Rà `TODO_before_submission.md` lần cuối; chạy checker LaTeX, kiểm accessibility, plagiarism/self-overlap, camera-ready.
- ☐ Render lại mọi hình/bảng sau thay đổi class cuối; lặp `figure_quality_audit.md`.
- ☐ Nộp **trước** hạn $\geq$ 4 ngày (mục tiêu 22/01/2027; hạn 26/01/2027; đăng ký bắt buộc 19/01/2027).

PHẦN N — Audit bảo trì (chạy lại sau mỗi thay đổi lớn)

- ☐ `math_audit.md` + `theorem_dependency_graph.md` sau đổi định lý.
- ☐ `notation_consistency_check.md` sau đổi ký hiệu.
- ☐ `citation_consistency_report.md` + `citation_claim_map.csv` sau đổi trích dẫn.
- ☐ `figure_quality_audit.md` sau render lại hình.
- ☐ `claim_strength_audit.md` sau đổi tuyên bố.
- ☐ `topic_alignment_check.md` + `idea_fidelity_report.md` sau đổi phạm vi/đóng góp.
- ☐ `SecretHandle/audits/*` sau mỗi thay đổi ngữ nghĩa mã.
- ☐ `reviewer_audit.md` sau mỗi vòng soát.

Rủi ro chính & phương án

Rủi ro	Phương án
Tác nhân ADB chạy UID shell/root	D3; đánh giá `adb unroot` + SELinux enforcing; thử 3 kiểu principal
Bề mặt nguồn lộ OTP trước `ENTER`	Che theo cửa sổ nguồn; fail-closed; kiểm trong tấn công họ 1
Redaction ảnh chụp trước khi map khó	Lùi về che cửa sổ/bỏ frame; ghi giới hạn
Nút cổ chai Track A (1 kỹ sư)	Cắt T3; walking skeleton sớm; nhân mốc A ×1,5
Thông lượng thiết bị & chi phí LLM	Emulator/Cuttlefish; tách tấn công kịch bản; trần chi phí API
Bản thảo 53 trang vượt giới hạn	Rút từ W9; chứng minh/thí nghiệm sang phụ lục
Không kịp có số đo thật	Bắt buộc killer + ma trận T1; không chuyển placeholder thành kết quả

5 hành động tiếp theo (ưu tiên ngay, tuần này)

1. ■ Chốt **D0–D5** trong `SecretHandle/docs/design_decisions.md` (đã hoàn tất 2026-10-17).
2. ☐ Kích hoạt **`repo sync` AOSP** (việc độ trễ dài nhất) + ghim commit/thiết bị.
3. ☐ Dựng môi trường dev (`pip install -e '.[dev]'`), xác nhận `ruff`/`mypy`; chạy `python -m pytest -q`.
4. ☐ Khởi động **cấp phát dài hạn**: license AndroidWorld/SPA-Bench, API model + trần chi phí, EC2 cô lập.
5. ☐ **Tái hiện B0** trên Android stock + dựng disclosure monitor bản đầu.

Ghi chú: Khi một mục xong, đổi ☐ → ■ và ghi ngày. Khi cổng G0–G4 đạt, viết biên bản cổng ngắn (kết quả đo, quyết định, thay đổi phạm vi). Biên dịch: `xelatex MASTER_CHECKLIST.tex` hai lần.